DOCUMENTATION · SECURITY

SBOM and release verification

The latest version is at anantharajuc.github.io/QueryAPIGate-website/Guide.dc.html?d=SBOM. This copy was made on 4 November 2026.

This pack describes **QueryAPIGate 0.34.2**. The SBOM is not copied into the pack: it is attached to each released image, signed, and you should read it from the exact image you run, by digest. This page says where it is and how to check that it, and the image, came from the project's release workflow.

What is published with every release (since 0.31)

ARTEFACT	FORM
Container image, `linux/amd64` and `linux/arm64`	Signed keyless with cosign, by digest, in both the Sigstore bundle and the classic `.sig` form
SBOM, per platform	SPDX 2.3, attached to the image as an in-toto attestation
Build provenance, per platform	SLSA provenance v1, attached to the image
GitHub attestation	Names the repository, workflow, commit and run
Helm chart	Signed the same way, published at the server's version

Releases before 0.31 are not signed. Background: ADR 0018: Signed releases.

0.34.2 at a glance

	REFERENCE
Image	`ghcr.io/anantharajuc/queryapigate:0.34.2`
Image index digest	`sha256:25511ebc7b89e1dfdbe6a55e4a9ef3e10d9049e82aefba8cba72b4c0884ff1b2`
`linux/amd64` image	`sha256:8237acc69bc9ebe7f2346cb72837d8383a9ffb374ab83e9582b17a30b7d4754a`
`linux/arm64` image	`sha256:2c6d5a0288cde1ffbebae0983b46c6288c2f4509e8146318f183b67199c42c8b`
Helm chart	`oci://ghcr.io/anantharajuc/charts/queryapigate` version `0.34.2`, digest `sha256:fd233bbf9d36a9973828c0d9515c10d05f31c91208b3a1f6c34b0545a8d29385`
Signing identity	`https://github.com/AnanthaRajuC/QueryAPIGate/.github/workflows/docker.yml@refs/tags/v0.34.2`
OIDC issuer	`https://token.actions.githubusercontent.com`

The digests were read from the registry when this pack was built. Pull by digest, and verify before you run.

Read the SBOM

```shell
docker buildx imagetools inspect ghcr.io/anantharajuc/queryapigate:0.34.2 --format '{{json .SBOM}}'
```

One SPDX 2.3 document per platform. Feed it to your scanner (Grype, Trivy) to see which advisories apply, without pulling the image.

Verify the signature

```shell
cosign verify
ghcr.io/anantharajuc/queryapigate@sha256:25511ebc7b89e1dfdbe6a55e4a9ef3e10d9049e82aefba8cba72b4c0884ff1b
2 \
  --certificate-identity
https://github.com/AnanthaRajuC/QueryAPIGate/.github/workflows/docker.yml@refs/tags/v0.34.2 \
  --certificate-oidc-issuer https://token.actions.githubusercontent.com
```

Keyless means there is no key to trust or rotate: the signing certificate names the workflow and the tag it ran on, and the signature is recorded in Sigstore's public transparency log.

Verify how it was built

```shell
gh attestation verify oci://ghcr.io/anantharajuc/queryapigate:0.34.2 --owner AnanthaRajuC
```

or, with cosign, `cosign verify-attestation --new-bundle-format --type https://slsa.dev/provenance/v1` with the same identity and issuer as above. The provenance names the repository, the workflow, the commit and the run; the image's own build provenance records the base images by digest.

Admit only signed releases to a cluster

Sigstore's policy-controller and Kyverno can refuse any image this workflow did not sign on a release tag. The policies, and the outputs they give for signed, unsigned and wrongly signed images, are in Verify a release before you run it.

How builds are pinned

Every GitHub Action in the release workflow is pinned by commit SHA and the base images by digest; a test fails on anything unpinned (0.31.0).